

Bienvenidos



Ciberseguridad en la protección de red

Conceptos básicos de defensa en profundidad

Javier Benvenuto Servat

jbenvenuto@esan.edu.pe

Agenda

- Clasificación de activos de información.
- Defensa en profundidad.
- Componentes lógicos de defensa en profundidad.

Clasificación de activos de información

Cuando hablamos de Seguridad de Información y Seguridad informática, siempre debemos tener en cuenta la clasificación de los activos de información.

Para en base a ello definir que controles, más exhaustivos o laxos tendrán en base a su valoración y como usualmente no se puede hacer todo en paralelo, hay que secuenciar actividades en base a una priorización

Clasificación de Activos y asignación de propietarios



Valoración de Activos

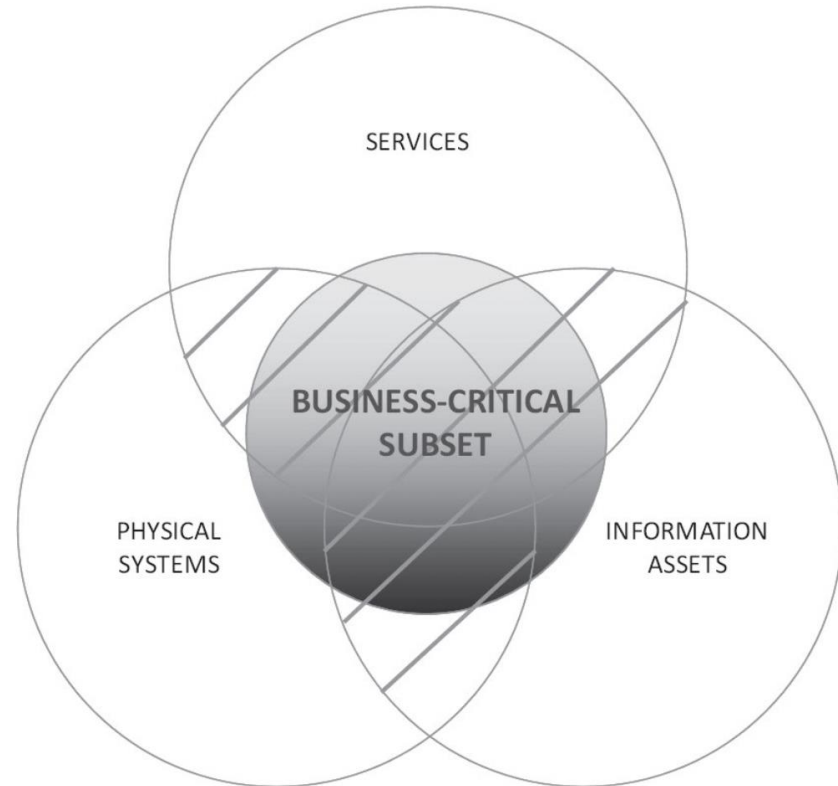
Ahora, se deberá determinar los valores de cada uno de los activos en base a su nivel de confidencialidad, disponibilidad e integridad, considerando los siguientes valores de impacto:

Matriz de Impacto

NIVEL	DESCRIPTOR	DESCRIPCIÓN
1	Insignificante	Si el hecho llegara a presentarse, tendría consecuencias o efectos mínimos sobre la entidad.
2	Menor	Si el hecho llegara a presentarse, tendría bajo impacto o efecto sobre la entidad.
3	Dañino	Si el hecho llegara a presentarse, tendría medianas consecuencias o efectos sobre la entidad.
4	Severo	Si el hecho llegara a presentarse, tendría altas consecuencias o efectos sobre la entidad.
5	Crítico	Si el hecho llegara a presentarse, tendría desastrosas consecuencias o efectos sobre la entidad.

Clasificación de activos ~~de información~~ Críticos

Cuando hablamos de Ciberseguridad, el alcance debe priorizar el subconjunto de sistemas críticos para el negocio. La intersección entre servicios, activos de información y sistemas físicos.



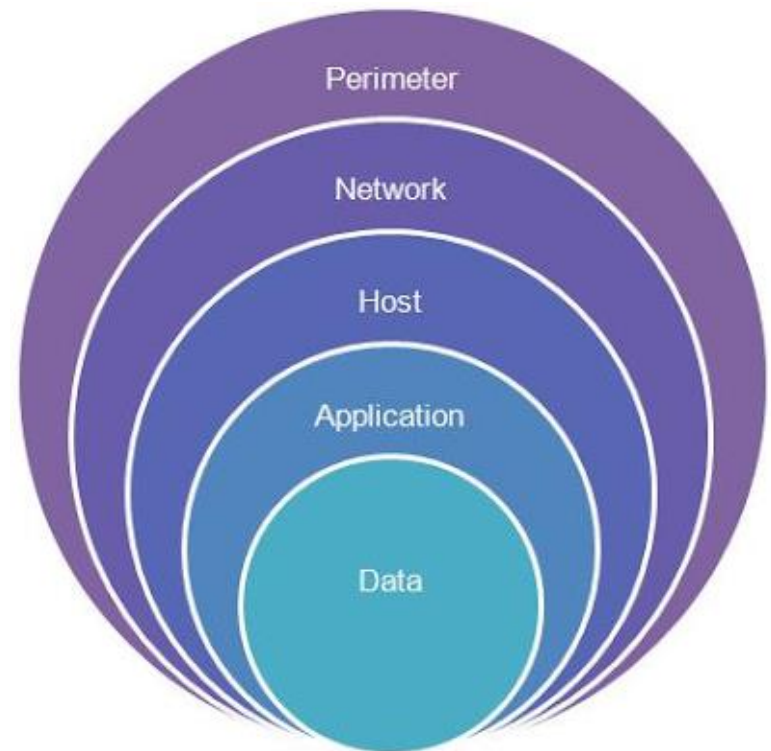
Defensa en profundidad

Defense in Depth (DiD) es un modelo o enfoque de Ciberseguridad. Algunos también la llaman estrategia*.

*Pero en realidad la estrategia va más allá de la elección de un modelo, tiene que ir acompañada del apetito del riesgo y la elección de que se va a priorizar (cumplimiento, buenas prácticas, estándares, ISOs, frameworks, etc) y como.

Incluye una serie de mecanismos y controles de Ciberseguridad que se superponen cuidadosamente en una red informática para proteger la confidencialidad, la integridad y la disponibilidad de la red y los datos que contiene.

Si bien ninguna mitigación individual puede detener todas las amenazas cibernéticas, juntas brindan mitigaciones contra una amplia variedad de amenazas al tiempo que incorporan redundancia en caso de que falle un mecanismo. Cuando tiene éxito, este enfoque refuerza significativamente la seguridad de la red contra muchos vectores de ataque.



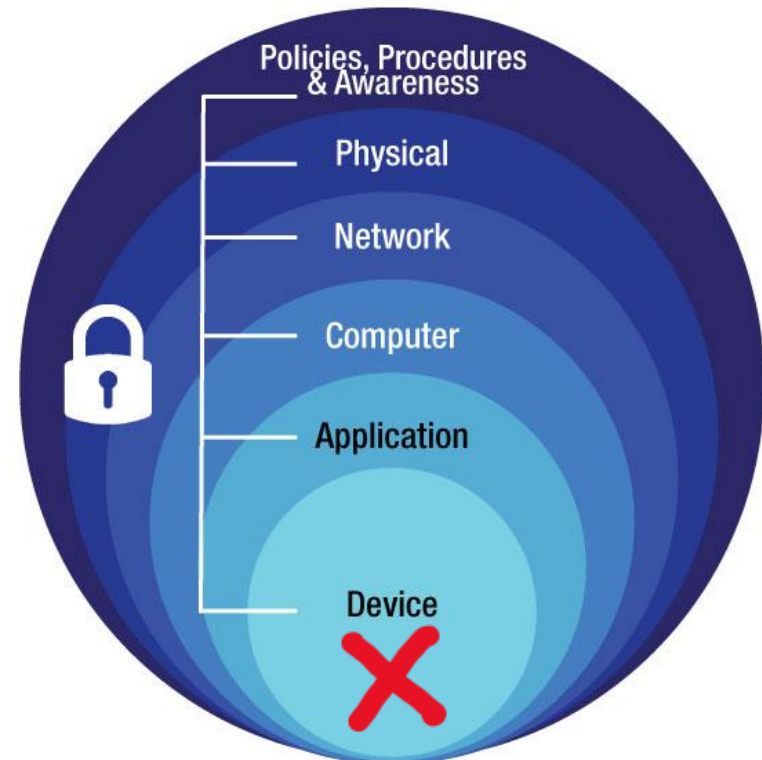
Defensa en profundidad (errada)

Defense in Depth (DiD) Misconception*.

*Error conceptual

Join at **www.kahoot.it**
or with the **Kahoot! app**

El objetivo primordial a ser resguardado son los activos de información (Data) no los dispositivos (Device) salvo que se trate de un dispositivo de infraestructura crítica.



Defensa en profundidad

Tener en cuenta las 7 capas del modelo OSI, los protocolos y vectores de ataque para luego ver que herramientas se pueden poner por capa.

N°	Capa	Layer	Protocol	Attacks
7	Aplicación	Application	HTTP, HTTPS, FTP, SMTP, DNS	Malware, DoS, SMTP attack, FTP Bounce, Data Attack, Insecure HTTP, Browser Hijacking, Buffer Overflow
6	Presentación	Presentation	Data representation and Encryption	Malformed SSL, SSL Striping, Unicode Vulnerabilities, Worms.
5	Sesión	Session	WEB Sockets, Session cookies	Session Hijacking, DoS
4	Transporte	Transport	TCP, UDP, SSL	TCP Flood, Desynchronizing flooding, TCP Sequence Prediction Attack
3	Red	Network	IP, ICMP	Spoofing, Hijacking, Ping Floods, MiTM (Man in The Middle attacks)
2	Enlace	Data Link	MAC, Ethernet	MAC Spoofing, Collision, Switch looping, Traffic analysis.
1	Físico	Physical	Cables, WiFi	Wire Tapping, Jamming, Tampering

Defensa en profundidad – 3 Defectos

El punto de vista de la Arquitectura de Red.

Supone un camino directo desde Internet, a través de un gateway (en la capa de red) a un host y aplicación/datos.

Las redes modernas son complejas con aplicaciones en la nube, múltiples gateways, dispositivos móviles, etc

Capacidades superpuestas o descontinuadas

Gasto excesivo en la superposición de capacidades que abordan el mismo vector de amenaza o ataque. Ej. NIPS y HIPS usando las mismas firmas.

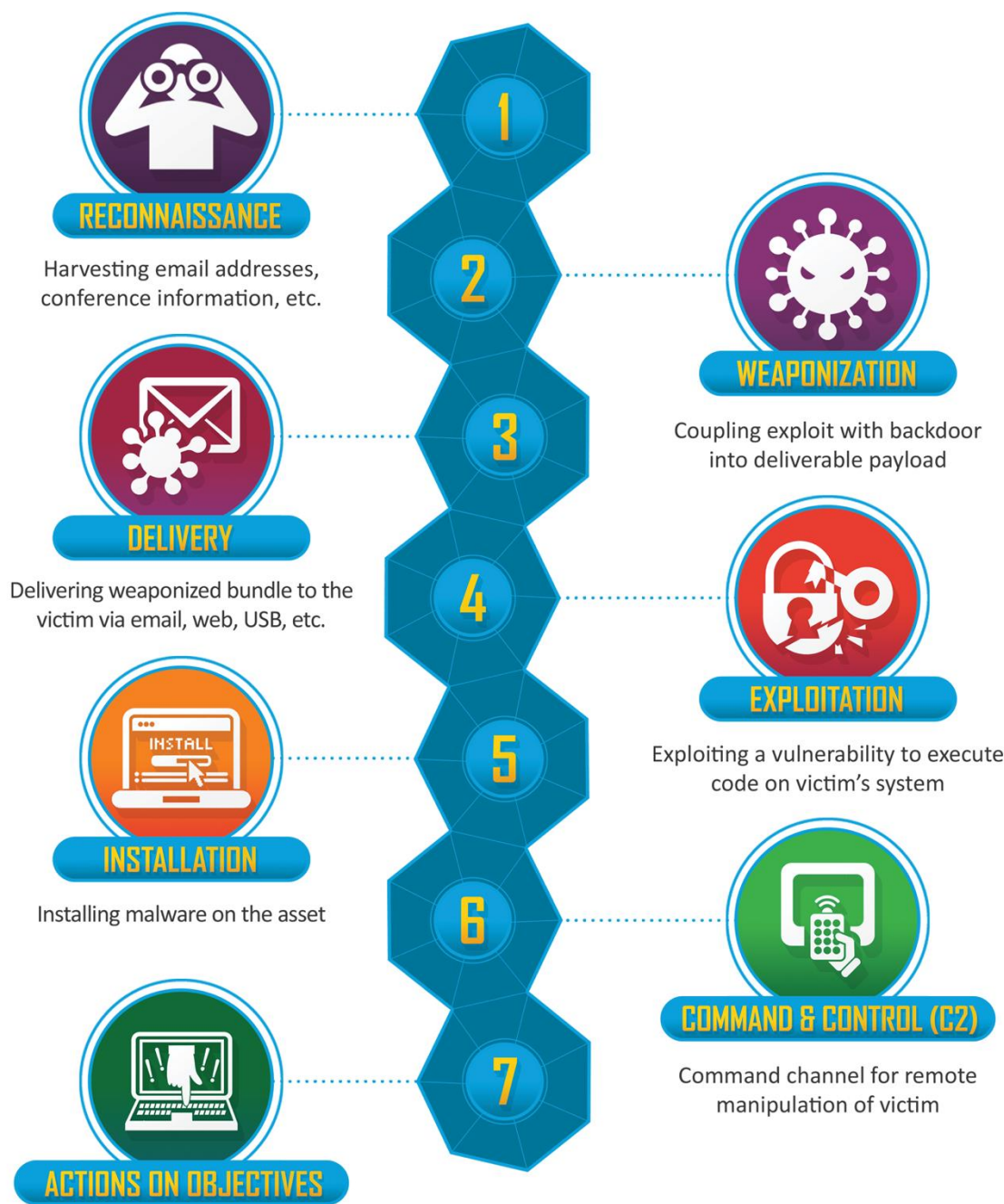
Uso de algunas descontinuadas.
Ej. FW vs NGFW

Perspectiva de amenaza limitada.

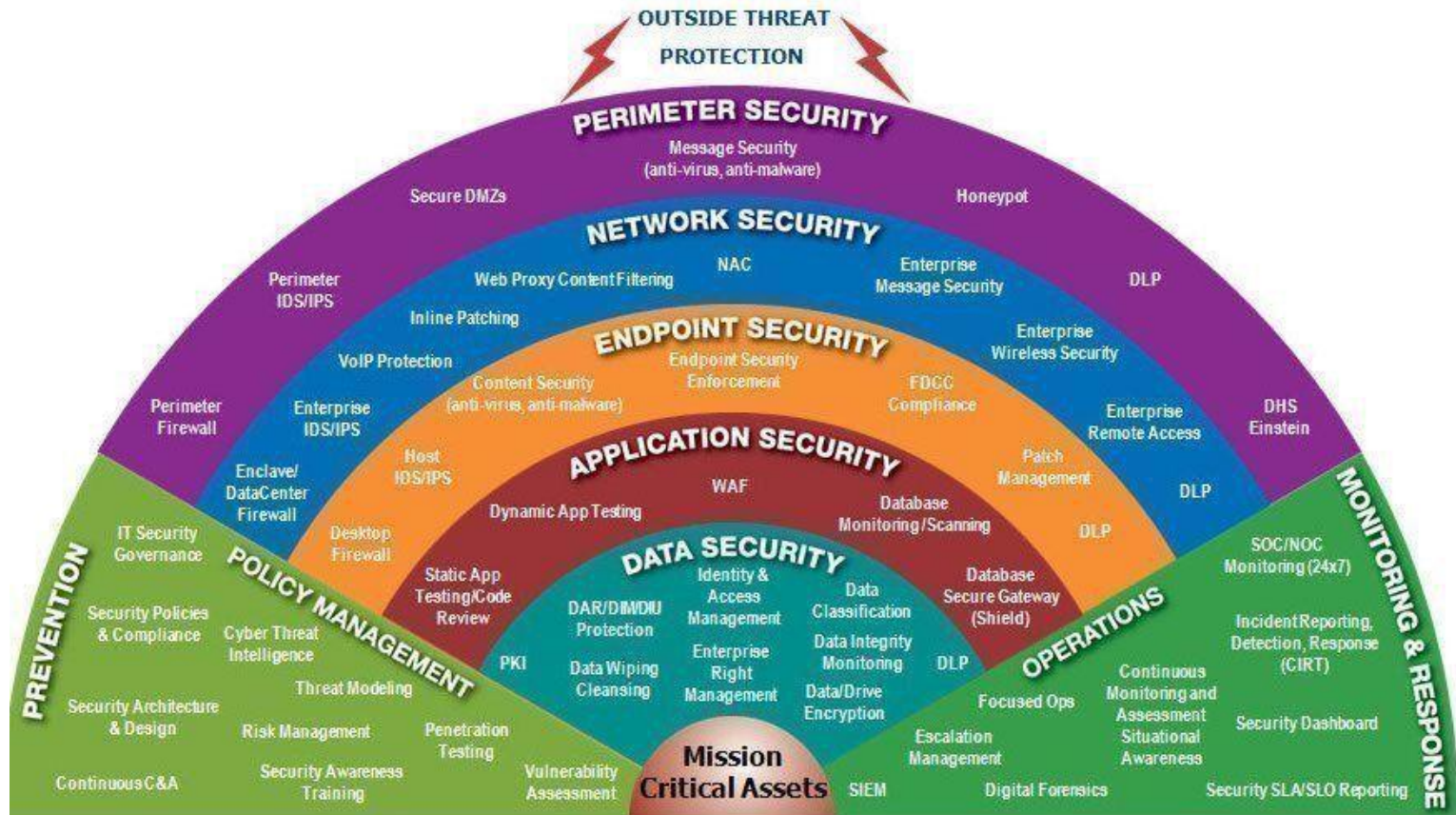
No toma en cuenta ningún modelo [Kill-Chain.](#)

Presupone que son suficientes todas las capas para prevenir los ataques.

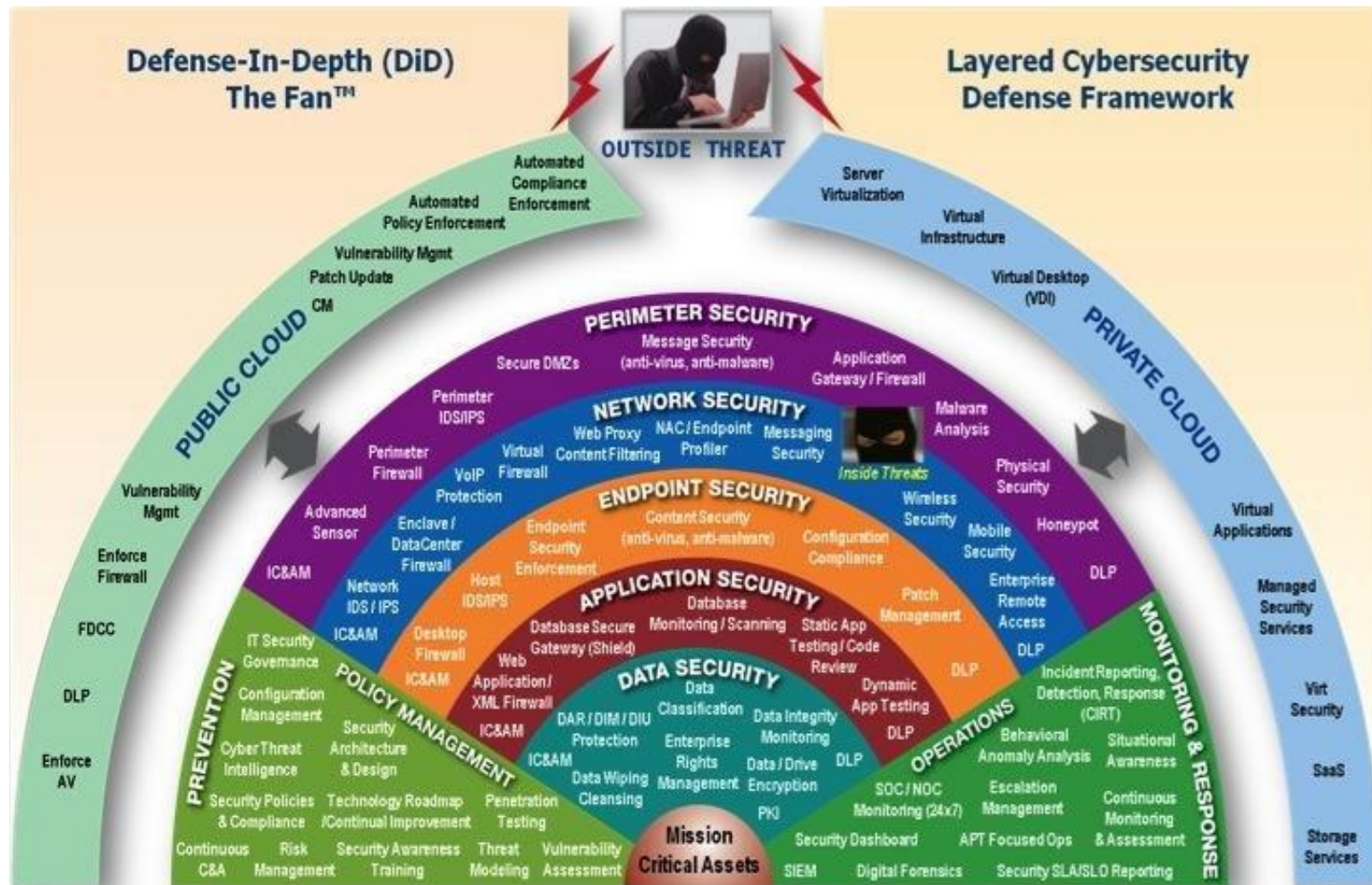
No incluye inteligencia de amenazas, respuesta y resiliencia.



Defensa en profundidad +



Defensa en profundidad. The Fan™



© 2010, 2012 Northrop Grumman Corporation

Componentes lógicos de DiD

Los componentes lógicos de la Defensa en profundidad: Son los puntos de control y sus capas: Las mismas son conceptuales y no necesariamente reflejan la realidad física.

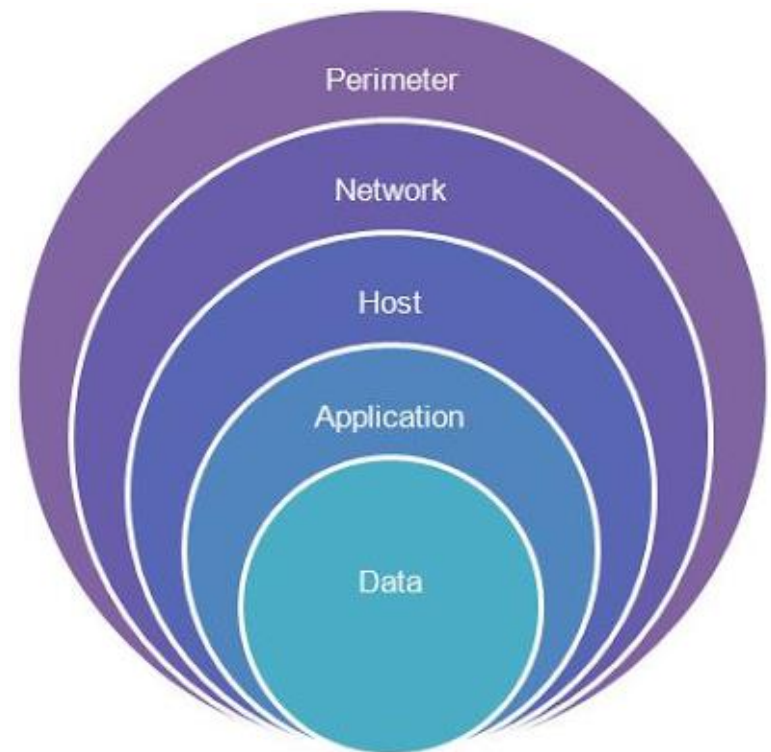
El Perímetro: Probablemente siempre tengamos uno externo, no es el único. Podemos tener varios de acuerdo a la segmentación de la red y los dominios de seguridad creados en la empresa.

La Red: No toda es plana ni propia.

El Host: Puede estar en varias ubicaciones, puede contener una o más aplicaciones.

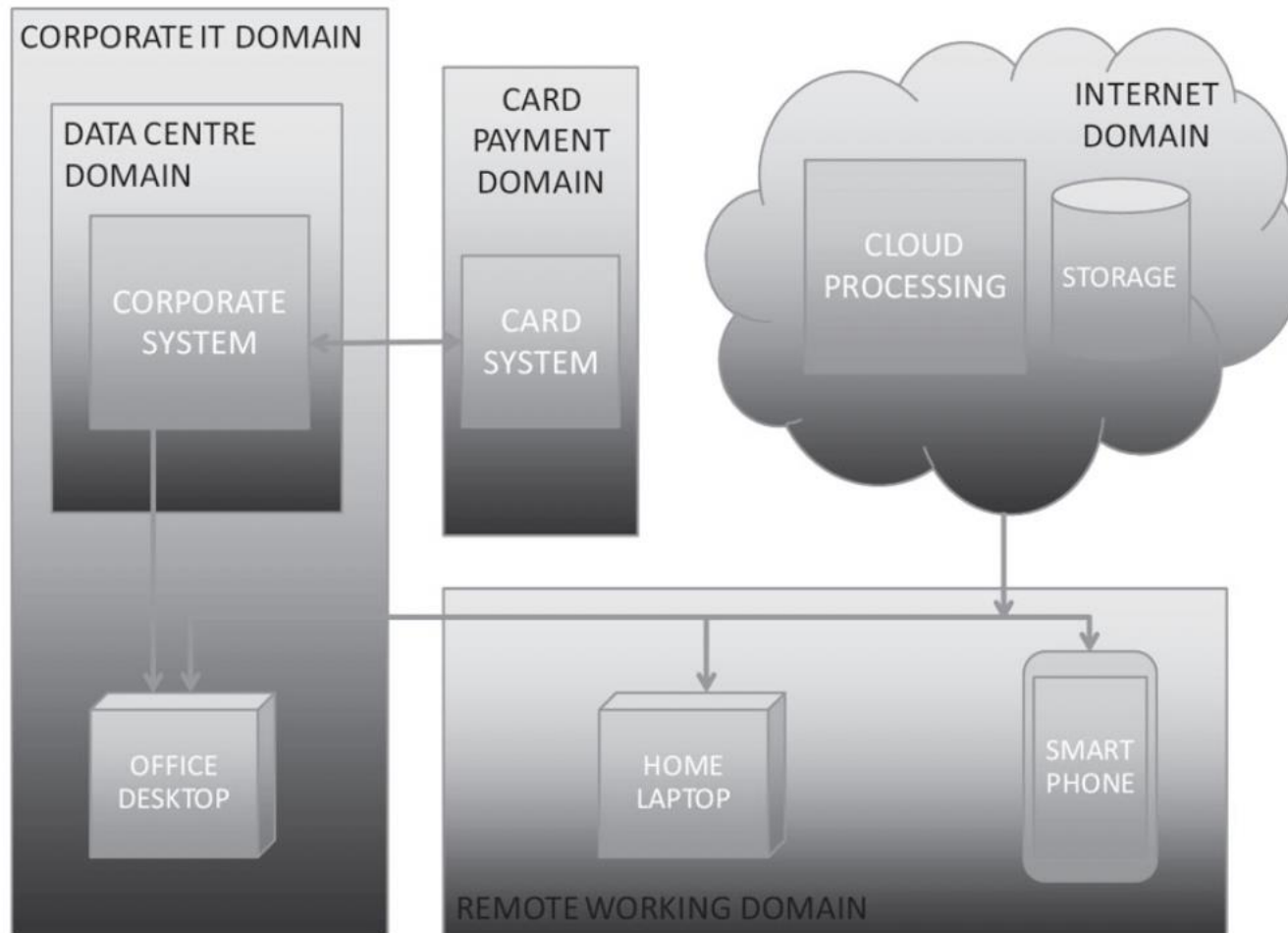
Las Aplicaciones: No dependen de un solo Host.

La Data: No siempre está al último y tiene estados (en tránsito, en reposo o en proceso)

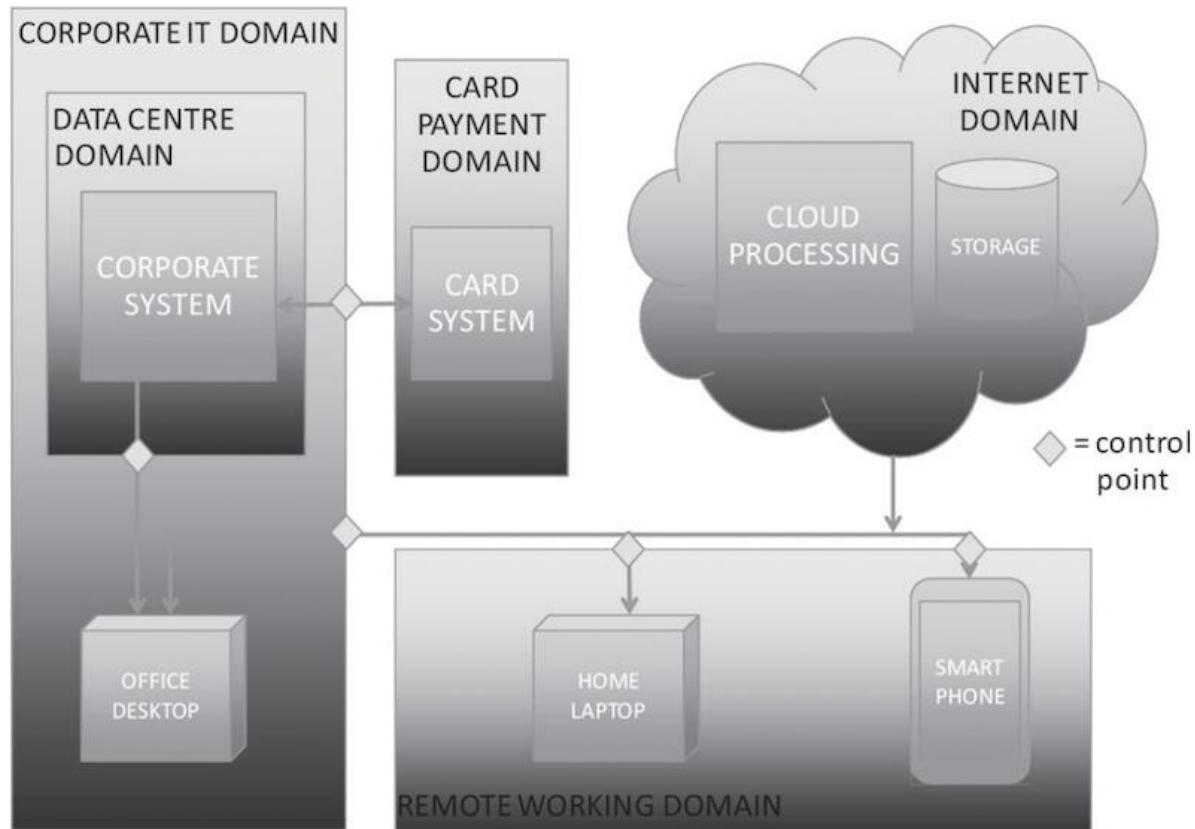


Componentes lógicos de DiD

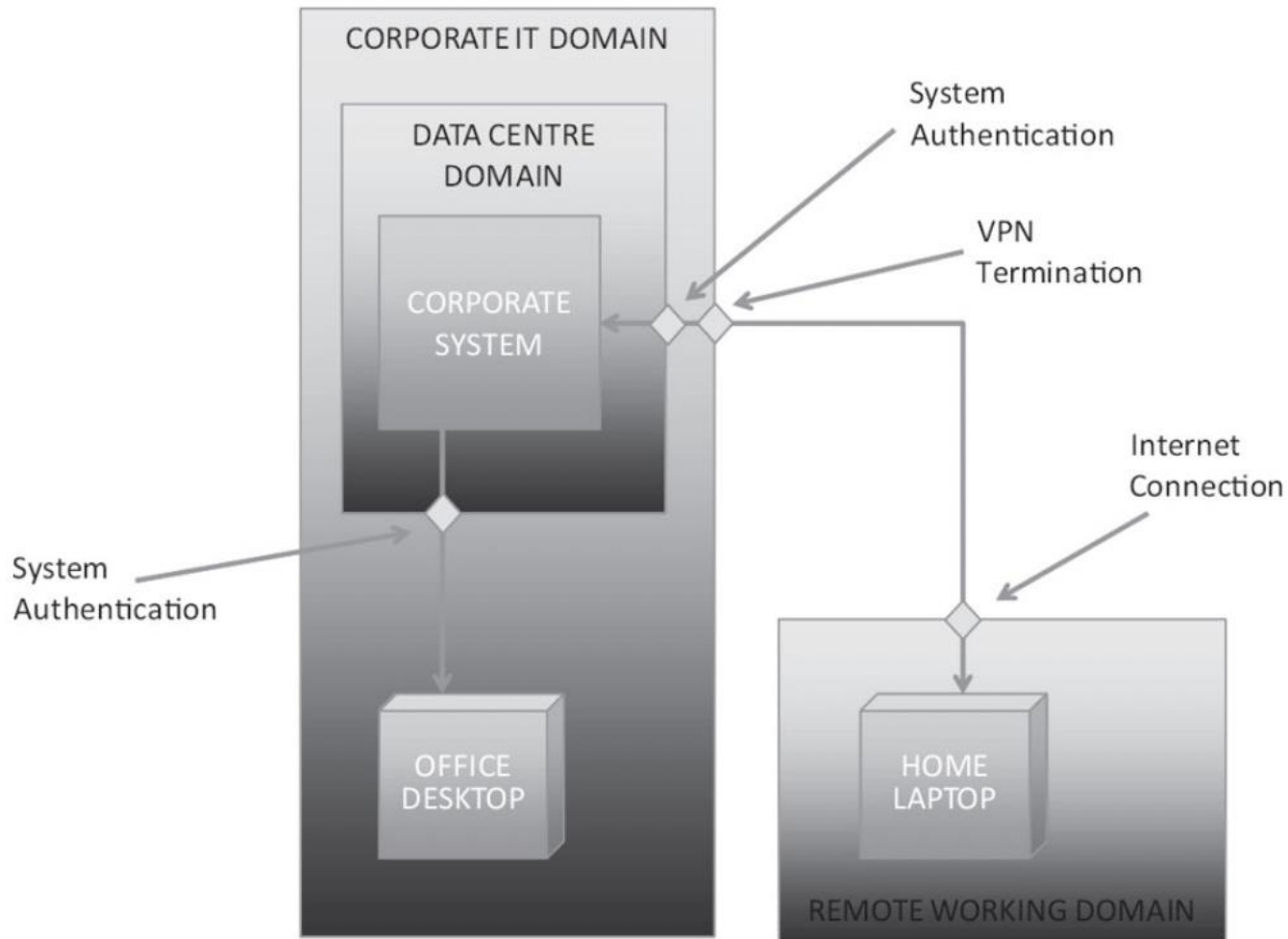
Figure 2.3 Security domains group technology elements that need to be secured in a similar way



Componentes lógicos de DiD



Componentes lógicos de DiD



Bibliografía recomendada:

<https://www.scribd.com/book/384123805/Security-Architect-Careers-in-information-security>

<https://news.northropgrumman.com/news/releases/northrop-grumman-responds-to-federal-agency-needs-for-stronger-cloud-security-solutions>

<https://www.northropgrumman.com/cybersecurity>

<https://cisotimes.com/defense-in-depth-the-layered-approach-to-cybersecurity/>

<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

Conclusiones

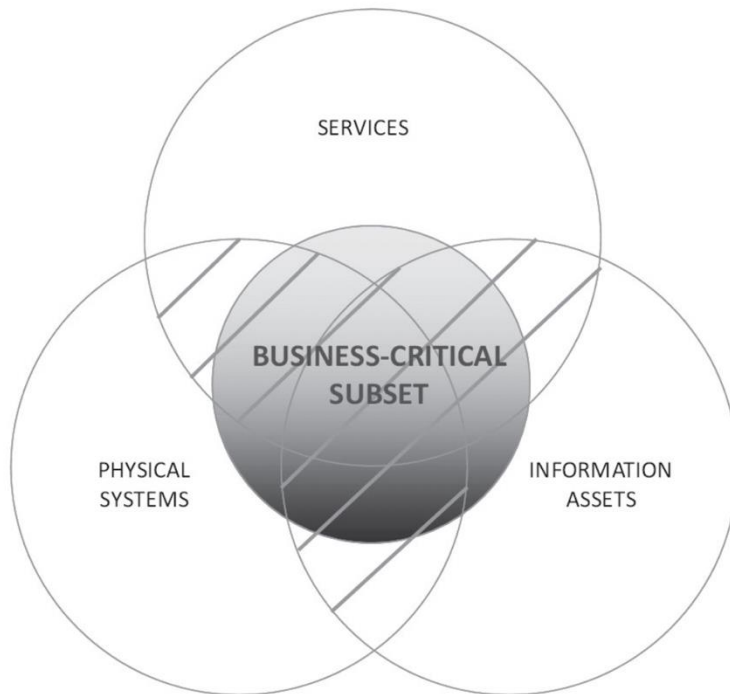


Wrap up!

Resumiendo

Para definir el alcance:

- Clasificación de Activos.
- Valorización de Activos.
- Priorizar el aseguramiento de los sistemas críticos del negocio.



Defensa en profundidad:

- Es un modelo, un approach o abordaje.
- No es una estrategia.
- Tiene por lo menos 5 capas.
- Incluye mecanismos y controles que se superponen.
- Es importante tener en cuenta las 7 capas del modelo OSI para la elección de herramientas.

